

1. Ce este triada CIA (Confidentiality, Integrity, and Availability)?

- **Confidențialitatea** asigură protejarea vieții private a datelor prin restricționarea accesului prin autentificare și criptare.

- Un alt termen pentru confidențialitate ar putea fi intimitatea.
- Politicile companiei ar trebui să restricționeze accesul la informații doar pentru personalul autorizat și să se asigure că doar acele persoane autorizate pot vizualiza aceste date.
- Datele pot fi compartimentate în funcție de nivelul de securitate sau de sensibilitate al informației.
- De exemplu, un dezvoltator de programe Java nu ar trebui să aibă acces la informațiile personale ale tuturor angajaților.
- Angajații ar trebui instruiți în protejarea informațiilor sensibile, pentru a se proteja pe ei înșiși și compania de atacuri.
- Metodele pentru asigurarea confidențialității includ criptarea datelor, ID-ul și parola de utilizator, autentificarea în doi pași și minimizarea expunerii informațiilor sensibile.

- **Integritatea** asigură că informațiile sunt corecte și de încredere

. Integritatea se referă la precizie, consistență și încredere în date pe tot parcursul ciclului lor de viață.

- Datele trebuie să rămână neschimbate în timpul transmiterii și să nu fie modificate de entități neautorizate.
- Permiisiunile de fișiere și controlul accesului utilizatorilor pot preveni accesul neautorizat.
- Controlul versiunilor poate fi folosit pentru a preveni modificările accidentale de către utilizatorii autorizați.

Copiile de siguranță trebuie să fie disponibile pentru a restaura datele corupte, iar funcția de verificare a integrității poate fi utilizată pentru a verifica integritatea datelor în timpul transferului.

- O sumă de control (checksum) este folosită pentru a verifica integritatea fișierelor sau șirurilor de caractere după ce au fost transferate de pe un dispozitiv pe altul prin intermediul rețelei locale sau pe Internet.
- Checksum-urile sunt calculate cu funcții de hash. Unele dintre checksum-urile comune sunt MD5, SHA-1, SHA-256 și SHA-512.
- O funcție de hash utilizează un algoritm matematic pentru a transforma datele într-o valoare de lungime fixă.
- Valoarea de hash este pentru comparație.
- Din valoarea de hash, datele originale nu pot fi recuperate direct.

- **Disponibilitatea** garantează că informațiile sunt accesibile persoanelor autorizate.

Menținerea echipamentelor, efectuarea mentenanțelor hardware, menținerea sistemelor de operare și a software-ului la zi și crearea copiilor de siguranță asigură disponibilitatea rețelei și a datelor.

- Trebuie să existe planuri pentru recuperare rapidă în caz de dezastre naturale sau cele provocate de om.
- Echipamentele sau software-ul de securitate (firewall-urile) protejează împotriva opririi serviciilor din cauza atacurilor de tip Denial of Service.
- Atacul de Denial of Service (DoS) apare atunci când un atacator încearcă să supraîncare resursele astfel încât serviciile să nu fie disponibile utilizatorilor.

2. Ce cuprinde Securitatea rețelelor?

– **Protecția Datelor Sensibile:** Unul dintre obiectivele principale ale securității rețelelor este asigurarea confidențialității datelor. Aceasta se realizează prin criptarea datelor pentru a le proteja de accesul neautorizat.

- **Prevenirea Atacurilor Cibernetice:** Securitatea rețelelor vizează protejarea rețelei și a dispozitivelor sale de atacurile cibernetice, cum ar fi malware (virus, troieni, ransomware), phishing, atacuri DDoS și alte amenințări.
- **Controlul Accesului:** Securitatea rețelelor implică implementarea unor politici stricte de control al accesului, astfel încât numai utilizatorii autorizați să aibă acces la anumite resurse sau date.
- **Securitatea Wireless:** Rețelele wireless sunt, de asemenea, expuse la amenințări cibernetice. Securitatea wireless implică protejarea rețelei Wi-Fi prin utilizarea de politici de parole, criptare și segmentarea rețelelor.
- **Securitatea Dispozitivelor:** Toate dispozitivele conectate la rețea trebuie să fie securizate. Acest lucru implică instalarea de software de securitate, actualizarea constantă a dispozitivelor și monitorizarea activității acestora.
- **Securitatea Fizică:** În plus față de măsurile tehnologice, securitatea rețelelor include și protejarea infrastructurii fizice, cum ar fi comutatoarele, routerele și cablurile.
- **Detectarea și Răspunsul la Incidente:** Un alt aspect important este capacitatea de a detecta eventualele incidente de securitate și de a reacționa rapid pentru a minimiza daunele.
- **Conștientizarea Utilizatorilor:** Utilizatorii rețelei joacă un rol esențial în securitatea acesteia. Prin conștientizarea securității, utilizatorii pot evita să cadă pradă amenințărilor cibernetice.
- **Conformitatea cu Reglementările:** Multe industrii și organizații sunt supuse regulilor și reglementărilor stricte privind securitatea datelor. Securitatea rețelelor trebuie să respecte aceste cerințe.
- **Evoluția Tehnologică:** Pe măsură ce tehnologia avansează, noile amenințări apar. Securitatea rețelelor trebuie să țină pasul cu aceste evoluții și să adapteze continuu strategiile de protecție.

3. VLAN-uri. Introducere. Numere de VLAN. Configurare.

Un **VLAN** (Virtual Local Area Network) este o tehnologie de rețea de nivel 2 (OSI , data link) care segmentează logic o rețea fizică unică în mai multe rețele virtuale distincte. Acesta grupează dispozitivele în funcție de funcții sau securitate, indiferent de locația lor fizică, îmbunătățind performanța prin reducerea domeniilor de difuzare (broadcast) și crescând securitatea prin izolarea traficului .

În securitatea datelor se folosesc VLAN-uri ca soluție a cerințelor : adică : cerințe ale rețelei locale

- Trebuie separate domeniile de broadcast pentru a folosi eficient lățimea de bandă.
- Sistemele de calcul din aceeași departament ar putea trebui grupate pentru a avea acces la servicii.
- Securitate: restricționarea accesului anumitor utilizatori la anumite zone ale LAN-urilor.
- O modalitate ca diferitele zone ale LAN-ului să poată comunica între ele.

Apartenența la VLAN poate fi determinată în funcție de rol și nu de locație.

- VLAN-urile sunt gestionate de switch-uri.
 - Este nevoie de un router pentru comunicarea între VLAN-uri.
 - Toate host-urile dintr-un VLAN au adrese în aceeași subrețea. Un VLAN este o subrețea.
 - Broadcast-urile sunt păstrate în interiorul VLAN-ului. Un VLAN este un domeniu de broadcast.
 - Switch-ul are o tabelă de adrese MAC separată pentru fiecare VLAN.
- Traficul pentru fiecare VLAN este ținut separat de celelalte VLAN-uri.
- Switch-urile de nivel 2 nu pot realiza routarea între VLAN-uri.

Introducere : • VLAN-urile oferă segmentarea bazată pe domenii de broadcast.

- VLAN = Subrețea.

- VLAN-urile pot segmenta logic rețelele cu switch-uri bazându-se pe:
 - Locație fizică (Exemplu: Clădire)
 - Organizație (Exemplu: Marketing)
 - Funcție (Exemplu: Personal)



- VLAN-urile sunt create pentru a furniza servicii de segmentare furnizate tradițional de ruterele fizice în configurațiile de rețea locală (LAN).
- VLAN-urile abordează scalabilitatea, securitatea și gestionarea rețelei.

Numere de VLAN : • VLAN 1: rețeaua Ethernet implicită, inițial toate porturile în acest VLAN.

- Numerele de la 2 la 1001 pot fi folosite pentru VLAN-uri.
- Până la 255 de VLAN-uri pe switch-ul Catalyst 2960.
- Gama extinsă 1006 - 4094 este posibilă, dar cu mai puține funcționalități.

Configurare VLAN : poate fi realizată în mod static sau dinamic, în funcție de necesități:

- Statică:
 - Configurarea statică a VLAN-urilor implică atribuirea manuală a porturilor de switch la anumite VLAN-uri.
 - Administratorul rețelei determină ce porturi aparțin fiecărui VLAN și le configurează corespunzător.
 - Această abordare este mai potrivită pentru rețele mici sau medii cu cerințe de securitate mai stricte și o structură de rețea stabilă.
- Dinamică :
 - Configurarea dinamică a VLAN-urilor se bazează adesea pe protocoale precum VLAN Trunking Protocol (VTP) sau Generic VLAN Registration Protocol (GVRP).
 - Cu această abordare, adăugarea sau eliminarea de VLAN-uri se face în mod automat, în funcție de configurarea centralizată.
 - Aceasta este o opțiune mai scalabilă și ușurează administrarea rețelelor mari sau complexe, dar necesită atenție pentru a evita erorile de configurare.
- În ambele cazuri, obiectivul este de a izola domeniile de broadcast și de a gestiona eficient resursele rețelei.
- Configurația exactă poate varia în funcție de echipamentul și protocolul specific folosit în rețea.
- De obicei, se folosește interfața de administrare a switch-ului pentru a efectua aceste configurări.

4. Tipuri de VLAN. Trunking.

1. Clasificare după modul de configurare

VLAN-uri Statice (bazate pe port):

Sunt cele mai comune și presupun atribuirea manuală a porturilor switch-ului către un anumit VLAN.

Orice dispozitiv conectat la un anumit port devine automat membru al VLAN-ului asociat aceluiași port.

Sunt recomandate pentru rețele mici sau medii cu o structură stabilă și cerințe de securitate stricte.

VLAN-uri Dinamice:

Apartenența la VLAN se face automat, adesea pe baza adresei MAC a dispozitivului, nu a portului fizic.

Utilizează baze de date centrale și protocoale precum VTP (VLAN Trunking Protocol) sau GVRP pentru gestionare.

Sunt mai scalabile și utile în rețele mari, facilitând administrarea, dar sunt mai puțin comune decât cele statice.

2. Clasificare după modele de utilizare (Design)

VLAN-uri End-to-End (sau Campus-wide):

Sunt bazate pe **funcționalitatea** utilizatorilor (ex: un VLAN pentru departamentul de Contabilitate), indiferent de locația lor fizică în clădire.

Același VLAN ID poate fi regăsit în orice punct al rețelei.

VLAN-uri Geografice (sau Locale):

Sunt bazate pe **locația fizică** (ex: un VLAN pentru fiecare etaj sau cluster de switch-uri).

Acesta este modelul recomandat în prezent deoarece centralizarea resurselor face dificilă menținerea VLAN-urilor end-to-end.

3. VLAN-uri cu roluri speciale

VLAN 1 (VLAN-ul Implicit / Default):

Este configurat din fabrică pe toate porturile switch-ului.

Este utilizat pentru protocoale de control precum CDP (Cisco Discovery Protocol) și VTP.

Notă: VLAN 1 nu poate fi șters.

Este important să înțelegem că un link trunk nu aparține unui anumit VLAN. Responsabilitatea unui link trunk este să acționeze ca un canal pentru VLAN-uri între switch-uri și rutere (sau între switch-uri). Trunking în contextul VLAN-urilor reprezintă o tehnologie cheie în rețelele de calculatoare care permite transmiterea eficientă a mai multor VLAN-uri pe un singur link fizic între switch-uri sau routere.

1. Rolul unui link Trunk

Canal partajat: Un link trunk nu aparține unui singur VLAN, ci acționează ca un canal care transportă traficul mai multor VLAN-uri între switch-uri sau între switch-uri și routere.

Eficiență: Este mult mai eficient să se folosească un singur link fizic partajat pentru toate VLAN-urile în loc de a avea câte un cablu separat pentru fiecare VLAN creat.

2. Etichetarea cadrelor (VLAN Tagging)

Deoarece un singur cablu transportă date din mai multe rețele, switch-ul trebuie să știe cărui VLAN îi aparține fiecare cadru de date. Procesul funcționează astfel:

Adăugarea etichetei: Când un cadru intră pe un link trunk, switch-ul îi adaugă un identificator unic (tag) în antet care indică apartenența la un anumit VLAN.

Eliminarea etichetei: La celălalt capăt al link-ului trunk, switch-ul receptor citește identificatorul, îl elimină și trimite cadrul către portul corespunzător din acel VLAN.

3. Protocoale de Trunking

Există două metode principale menționate pentru realizarea etichetării:

IEEE 802.1Q (Dot1q): Este standardul industrial deschis și cel mai utilizat, fiind interoperabil între echipamente de la producători diferiți. Acesta adaugă o etichetă de 4 octeți în cadrul Ethernet.

ISL (Inter-Switch Link): Este un protocol proprietar Cisco, limitat la echipamentele acestui producător.

4. Configurare și Verificare

Pentru a activa trunking-ul pe o interfață, se folosesc comenzi specifice în modul de configurare al interfeței:

`switchport trunk encapsulation dot1q` – pentru a alege protocolul de etichetare (necesar pe unele modele de switch-uri înainte de a activa trunk-ul).

`switchport mode trunk` – pentru a forța portul să funcționeze ca un link trunk.

Probleme comune (Troubleshooting):

VLAN Nativ: Ambele capete ale link-ului trunk trebuie să aibă configurat același VLAN nativ pentru a evita erorile.

Modul de negociere: Ambele capete trebuie să fie configurate ca trunk sau să poată negocia activarea acestuia.

5. VLAN-uri si Tagging. IEEE 802.1Q.

• VLAN Tagging este utilizată atunci când un link trebuie să transporte trafic pentru mai mult de o VLAN. • Trunk link: pe măsură ce cadrele sunt primite de switch de la orice host conectat, se adaugă un identificator unic în cadrul fiecărui antet. Aceste informații din antet desemnează apartenența la VLAN a fiecărui cadru.

A. Conceptul de Tagging (Etichetare)

Tagging-ul este procesul prin care un switch adaugă informații suplimentare unui cadru Ethernet pentru a identifica VLAN-ul căruia îi aparține.

De ce este necesar? Pe un link Trunk circulă cadre de la mai multe VLAN-uri. Fără o „etichetă”, switch-ul de la celălalt capăt nu ar ști către care grup de utilizatori să trimită datele.

Funcționare: Când un cadru intră într-un port de acces, el este „curat” (standard). Când switch-ul îl trimite pe un port de Trunk, îi aplică o etichetă. Când cadrul ajunge la destinație și părăsește Trunk-ul către un port de acces, eticheta este eliminată.

B. Standardul IEEE 802.1Q (Dot1q)

Acesta este standardul industrial cel mai utilizat pentru tagging. Spre deosebire de protocoalele mai vechi (precum ISL), 802.1Q nu încapsulează întregul cadru, ci inserează un câmp de 4 octeți în antetul (header-ul) Ethernet original.

Structura etichetei (Tag-ului) 802.1Q:

Cele mai importante componente ale acestor 4 octeți sunt:

TPID (Tag Protocol Identifier): O valoare fixă (0x8100) care anunță că acesta este un cadru etichetat 802.1Q.

Priority (3 biți): Folosit pentru Quality of Service (QoS) – permite prioritizarea traficului (ex: vocea are prioritate față de date).

CFI pe un bit 0 - canonic , 1 - noncanonic

VLAN ID (VID - 12 biți): Aceasta este partea esențială. Identifică numărul VLAN-ului.

Deoarece sunt 12 biți, pot exista $2^{12} = 4096$ valori (de la 0 la 4095).

VLAN 1 este cel implicit.

C. VLAN-ul Nativ (Native VLAN)

O caracteristică specifică și obligatorie pentru standardul IEEE 802.1Q este conceptul de VLAN Nativ.

Definiție: Este singurul VLAN al cărui trafic trece prin trunk fără să fie etichetat (untagged).

Importanță: Implicit, VLAN-ul nativ este VLAN 1.

Regulă de aur: Ambele capete ale unui link Trunk trebuie să aibă configurat același VLAN nativ, altfel apar erori de comunicație și riscuri de securitate (VLAN hopping).

D. Procesul de rutare Inter-VLAN (Legătura cu Subiectul)

Deoarece VLAN-urile separă rețeaua la Nivelul 2 (Data Link), pentru ca datele să treacă dintr-un VLAN etichetat în altul, este nevoie de un dispozitiv de Nivel 3 (Router sau Switch Layer 3). Metoda clasică folosind Trunking și 802.1Q pe router se numește router-on-a-Stick.

6. De ce filtre de pachete ? Ce se filtrează. Avantaje. Dezavantaje.

Firewall-ul inspectează traficul care trece prin el.

- Permite traficul specificat în politica sa.
- Blochează restul.
- Două tipuri:

- **Filtre de pachete,**

- Proxy-uri.

- Filtul de pachete permite selectiv trecerea pachetelor de la o interfață de rețea la alta.
- De obicei, este realizat în cadrul unui router între rețelele externe și interne.
- Poate fi realizat și de un element de rețea dedicat, cunoscut ca "bridge de filtrare de pachete".

- Date disponibile (ce se filtrează)

- IP sursă și destinație

- Protocolul de transport (TCP, UDP sau ICMP)

- Porturile sursă și destinație TCP/UDP

- Tipul mesajului ICMP
- Opțiunile pachetului (dimensiunea fragmentului etc.)
- Acțiuni disponibile
 - Permiteți pachetului să treacă
 - Abandonați pachetul (notificarea expeditorului)
 - Înregistrați informații despre pachet
- Exemple de filtre– Blochează toate pachetele din exterior, cu excepția serverelor SMTP , Blochează tot traficul către o listă de IP, Blochează toate conexiunile de la un domeniu specific.
- **Avantaje:**
 - Transparent pentru aplicație/utilizator
 - Filtrele simple de pachete pot fi eficiente
- **Dezavantaje:**
 - De obicei, permit traficul în mod implicit (fail open)
 - Foarte dificil de configurat regulile
 - Nu are suficiente informații pentru a trigger-a acțiuni
 - Portul 22 înseamnă întotdeauna SSH? Nu neapărat, deoarece porturile pot fi configurate pentru diferite servicii.
 - Cine este utilizatorul care accesează SSH? Această informație nu este disponibilă într-un filtru de pachete.

7. La ce sunt folosite ACL-urile ? Unde se realizeaza filtrarea (nivele)?

- Un ACL, sau Listă de Control al Accesului, reprezintă un set de reguli sau configurații utilizate pentru a controla și filtra traficul de rețea. • ACL-urile sunt implementate de obicei pe dispozitive de rețea, cum ar fi routere și firewall-uri, pentru a determina ce pachete sunt permise să treacă și care sunt respinse.
- ACL-urile se împart în două tipuri principale:
 - ACL-uri **standard** sunt utilizate în principal pentru a filtra traficul în funcție de adresele IP sursă
 - ACL-uri **extinse** : oferă mai multă flexibilitate, permițând filtrarea în funcție de criterii diverse, inclusiv adresele IP sursă și destinație, numerele de port și protocoalele.

În ansamblu, ACL-urile reprezintă un component fundamental al securității rețelei și al gestionării traficului, ajutând administratorii de rețea să impună politici și să controleze fluxul de date în cadrul unei rețele.

ACL-urile sunt folosite în diverse scopuri, printre care:

- **Securitate:** ACL-urile pot fi folosite pentru a defini reguli care restricționează accesul la resursele de rețea, ajutând la protejarea rețelei de traficul neautorizat sau malefic. Ele pot filtra pachetele în funcție de adresele IP sursă și destinație, porturi și alte criterii.
- **Routare a Traficului:** ACL-urile pot fi utilizate pentru a controla routarea traficului într-o rețea. De exemplu, ele pot fi configurate pentru a determina calea pe care pachetele trebuie să o urmeze când trec de la un segment de rețea la altul.
- **Calitatea Serviciului (QoS):** ACL-urile pot fi utilizate pentru a prioriza sau deprioritiza anumite tipuri de trafic, asigurându-se că aplicațiile critice primesc resursele și lățimea de bandă necesare.
- Filtrarea pachetelor controlează accesul la o rețea prin analizarea pachetelor care vin sau pleacă și transmiterea lor sau respingerea lor în funcție de criteriile specificate.
- Filtrarea pachetelor poate avea loc la nivelul 3 sau la nivelul 4 (network si transport)

8. Functionarea ACL. ACL de intrare si iesire.

- ACL-urile definesc setul de reguli care oferă control suplimentar pentru pachetele;
 - care intră pe interfețele de intrare,
 - pachetele care tranzitează prin rută
 - pachetele care ies pe interfețele de ieșire ale ruterului.
- Un ACL de intrare filtrează pachetele înainte de a fi rutate către interfața de ieșire. • Dacă pachetul este permis de ACL, atunci este procesat pentru rutare. • ACL-urile de intrare sunt cel mai bine utilizate pentru a filtra pachetele atunci când rețeaua atașată la o interfață de intrare reprezintă singura sursă de pachete care trebuie examinate.
- Un ACL de ieșire filtrează pachetele după ce au fost rutate, indiferent de interfața de intrare. • Pachetele de intrare sunt rutate către interfața de ieșire și apoi sunt procesate printr-un ACL de ieșire. • ACL-urile de ieșire sunt cel mai bine utilizate atunci când același filtru va fi aplicat pachetelor care provin din mai multe interfețe de intrare înainte de a ieși pe aceeași interfață de ieșire.

9. De ce este nevoie de ACL extins – TCP established ?

ACL-urile extinse oferă un control mult mai granular decât cele standard, iar parametrul **TCP established** este o funcționalitate critică pentru securitatea traficului de întoarcere.

- **Context:**
 - În mod normal, dacă un utilizator din interiorul rețelei trimite o cerere către un server extern (ex: accesează un site web), traficul de răspuns de la acel server trebuie să poată intra înapoi în rețea.
 - Fără o regulă specifică, firewall-ul ar putea bloca acest răspuns, considerându-l trafic neinițiat din exterior.
- **Ce face parametrul "established"?**

- Această opțiune permite trecerea pachetelor TCP doar dacă acestea fac parte dintr-o **sesiune deja existentă** (inițiată din interior).
- Din punct de vedere tehnic, filtrul verifică dacă pachetul TCP are setat bit-ul **ACK** sau **RST** (indicând faptul că pachetul este un răspuns, nu o cerere nouă de conexiune).
- **De ce este nevoie de el? (Importanță):**
 - **Securitate:** Previne atacurile din exterior. Un atacator nu poate iniția o conexiune nouă către interior deoarece pachetele sale (care au doar bit-ul SYN setat) nu se vor potrivi cu regula "established".
 - **Control:** Permite administratorului să lase utilizatorii să navigheze pe internet, blocând în același timp orice tentativă a serverelor externe de a accesa calculatoarele din rețeaua internă neinvitate.
- **Limitări menționate în curs:**
 - Deși util, acest mecanism are limite: nu poate verifica dacă portul 22 este într-adevăr folosit pentru SSH sau dacă utilizatorul care accesează serviciul este cel autorizat. De asemenea, nu oferă același nivel de context ca un firewall de tip "stateful".

10. Ce este și la ce folosește Network Address Translation ?

Network Address Translation (NAT) este o metodă definită în RFC 3022 care permite conectarea adreselor IP private dintr-o rețea internă la Internet.

- **Ce este?**
 - Este un mecanism care realizează o mapare (translatare) între adresele IP private (ne-rutable în internet) și adresele IP publice.
 - Maparea poate fi de tip: **unu-la-unu** (o adresă privată la una publică) sau **unu-la-mai mulți** (mai multe adrese private la o singură adresă publică).
- **La ce folosește? (Rol și Scop):**
 - **Conectivitate:** Permite clienților cu adrese private (clasele A: 10.x.x.x, B: 172.16.x.x-172.31.x.x, C: 192.168.x.x) să acceseze resurse din Internet.
 - **Economisirea adreselor IP publice:** Prin utilizarea unei singure adrese publice pentru o întreagă rețea internă, se reduce cererea de adrese IPv4 globale.
 - **Securitate:** Îmbunătățește securitatea rețelei deoarece ascunde schema de adresare IP internă față de lumea exterioară.
 - **Flexibilitate:** Permite renumerotarea ușoară a adreselor IP interne fără a schimba adresa publică.

• NAT este disponibil în trei formate: – NAT static – NAT dinamic – PAT (Port address translation)

11. NAT static. Funcționare.

NAT-ul static este cea mai simplă formă de translatare, bazată pe o corespondență fixă.

- **Definiție:**
 - Reprezintă o mapare de tip **unu-la-unu** între o adresă IP locală (internă) și o adresă IP globală (publică).
- **Funcționare:**
 - Administratorul de rețea configurează manual o tabelă în router unde o adresă privată specifică este legată permanent de o adresă publică specifică.
 - Translatarea este **bi-direcțională**: funcționează atât pentru traficul care iese din rețea, cât și pentru traficul care intră.
- **Când se utilizează?**

- Este folosit în special pentru **serverele interne** (ex: server de web, server de mail) care trebuie să fie accesibile din Internet folosind o adresă publică constantă.
- **Avantaj/Caracteristică:**
 - Dispozitivul extern poate iniția o conexiune către dispozitivul intern folosind adresa publică mapată static, deoarece asociația din tabela NAT nu expiră niciodată.

Etapa 1. Adresa IP privată (internă) este translatată într-o adresă IP publică utilizată pentru a ajunge la serverul extern.

• Etapa 2. Adresa publică tradusă este folosită de server pentru a trimite informația cerută dispozitivului care are într-adevăr o adresă IP privată atribuită.

• Etapa 3. Router-ul NAT consultă tabela de rutare pentru a vedea care adresă privată a cerut datele.

12. NAT dinamic. Functionare.

• Routerul NAT mappează automat un grup de adrese IP locale valide la un grup de adrese IP de internet, după cum este necesar

• Administratorul rețelei nu se preocupă de adresa IP pe care o folosesc clienții interni

• Oricare adresă IP privată va fi tradusă automat în una dintre adresele IP de internet disponibile de către routerul NAT

• Adresele pentru NAT dinamic sunt extrase dintr-un pool predefinit de adrese publice

• NAT dinamic atribuie o adresă IP publică dintr-un pool de adrese fiecărui pachet care provine de la un dispozitiv cu o adresă IP privată atunci când acel pachet este destinat unei rețele din afara companiei. • Adresele sunt atribuite în ordinea sosirii, pe principiul "primul venit, primul servit".

• Numărul de dispozitive interne care pot transmite în afara companiei este limitat la numărul de adrese IP publice din pool.

PAT (port adress translation) este o forma de nat dinamic , cunoscuta ca si overloading .

• Serviciul NAT realizează redirecționarea portului

• Pentru a trimite conexiuni de la clienți externi la serverul Web din rețeaua internă

• Overlapping se întâmplă atunci când:

– Rețeaua internă a fost configurată greșit pentru o gamă de adrese IP care există de fapt pe Internet sau

– Două companii se unesc și fiecare companie folosea aceeași gamă de adrese IP private

• Poate fi rezolvat utilizând NAT, deoarece NAT ascunde schema IP internă configurată incorect

- PAT încearcă să păstreze numărul original al portului sursă. Dacă acel număr de port este deja în uz, PAT va asigna primul număr de port disponibil pentru grupul de porturi corespunzător:

- 0 – 511

- 512 – 1023

- 1024 - 65,535

- Când nu mai sunt disponibile numere de port, PAT trece la următoarea adresă IP publică din pool, dacă există una disponibilă.

Compararea NAT static vs PAT : • NAT static traduce adresele într-un raport 1:1.

- PAT folosește numere de port astfel încât o adresă publică să poată fi folosită pentru mai multe dispozitive cu adrese private. • PAT poate funcționa și cu protocoale precum ICMP, care nu folosesc TCP sau UDP.

13. Server-e Proxy. Functionare.

Proxy-urile pot:

- Ascunde utilizatorii finali într-o rețea

- Filtrează site-urile web nedorite

- Blochează conținutul dăunător (malware)

- Majoritatea serverelor proxy funcționează ca firewall-uri la marginile rețelelor

- Realizează filtrarea pachetelor, NAT și alte servicii

- Cunoscut și sub numele de servicii proxy, gateway-uri la nivel de aplicație sau proxy-uri de aplicații

- Sunt aplicații specializate de software firewall

- Evaluează datele la nivelul aplicației conținute în partea de date a unui pachet IP

- Cel mai comun este să se alocă un dispozitiv proxy unei singure aplicații

- Există proxy-uri HTTP pentru traficul web, SMTP pentru e-mail, etc.

- Filtrează tot traficul care intră și iese pe porturile relevante

- Decide dacă să blocheze sau să permită traficul pe baza regulilor stabilite de administrator

- Pașii implicați într-o cerere către serverul proxy:

- Un utilizator introduce URL-ul în browser.

- Serverul proxy primește cererea utilizatorului.

- Serverul proxy trimite cererea către serverul web.

– Serverul web trimite un răspuns înapoi la serverul proxy.

– Serverul proxy trimite răspunsul către utilizator.

- Principala problemă legată de serverele proxy: timpul pe care îl iau pentru a inspecta, compara și reconstrui pachetele și pentru a procesa cererile clientului.

Avantaje fata de ACL : • Înregistrări detaliate în log-uri: pot fi utile în investigarea incidentelor de securitate, monitorizarea traficului și înțelegerea utilizării rețelei.

- Reconstrucția pachetelor: au capacitatea de a modifica pachetele în tranzit. Este utilă pentru securitate și pentru a asigura compatibilitatea între rețele cu protocoale diferite.

- Protejarea utilizatorilor interni: sunt protejați de amenințări externe. Toate cererile și răspunsurile sunt intermediare de proxy, orice atacuri sau pachete măsluite din exterior nu ajung la host-urile interne.

- Blocarea atacurilor : acționează ca o barieră pentru atacurile care ar putea începe cu date de pachete corupte sau măsluite

Configuratii : - dual hammed (doua interfete una interna una externa) , cu filtrare (o interfata catre internet , traficul este permis doar daca este destinat unui serviciu de proxy) , ascunderea clientilor interni , blocarea url urilor , blocarea si filtrarea continutului , protectie a serverului de mail .

Avantaje : Imbunătățirea performanței • Uzual, încetinește cererile de date • Mărește viteza de acces la documente care au fost solicitate repetat prin stocarea paginilor web într-un cache • Fișiere Log (jurnale) foarte complete și complexe • Majoritatea serverelor proxy pot solicita utilizatorilor care se conectează la server un nume de utilizator și o parolă

14. Atacul de tip ARP Spoofing.

Address Resolution Protocol • Protocolul ARP permite unui host să mapeze adresa IP la adresa MAC asociată interfeței hardware a partenerului (de exemplu, Ethernet) pentru a fi utilizată în livrarea direct (sunt incapsulate in protocolul de nivel data link)

Hw type	Prot type	Hw size	Prot size	Op	Sender Ether	Sender IP	Target Ether	Target IP
---------	-----------	---------	-----------	----	--------------	-----------	--------------	-----------

- Hardware type (2 bytes), protocol type (2 bytes), hardware size (1 byte), and protocol size (1 byte) specifică mărimea adreselor Ethernet și IP, spre exemplu [0x0001, 0x0800, 6, 4]
- OP field specifică dacă este ARP request sau ARP reply (1= ARP request, 2=ARP reply)
- Sender Ethernet/IP: datele celui ce a făcut cererea
- Target Ethernet: empty la o cerere
- Target IP: adresa de IP cerută

Scopul atacului de tip ARP Spoofing este de a intercepta tot traficul dintre doua gazde intrun mediu de retea cu switch prin manipularea tabelor arp .

- Atacul se bazează pe natura fără stare a protocolului ARP. – Răspunsurile fără cerere vor fi acceptate.
- Acest tip de atac vizează host-urile dintr-o rețea pentru a direcționa traficul către un atacator.

15. ARP Spoofing contra-măsuri.

- ARP Spoofing Detection Tools: instrumente specializate pentru detectarea manipulărilor ARP în rețea. Aceste instrumente pot identifica activitățile suspecte și pot avertiza asupra posibilelor atacuri.

- Static ARP Entries: se configurează intrările ARP statice pentru adresele IP esențiale în rețea. Aceasta va împiedica modificările neautorizate ale tabelului ARP.
- Cache-ul ARP poate fi configurat pentru a ignora actualizările dinamice
- Difícil de gestionat în implementări mari
- Poate fi utilizat pentru un subset de adrese critice (de exemplu, servere DNS, gateway-uri)

- Rezistență la cache poisoning:• Se ignoră răspunsurile ARP nesolicitate (încă vulnerabile la hijacking)
- Se actualizează la expirare (utilitate limitată)

- Monitorizarea modificărilor: (de exemplu, arpwatch)
- Ascultarea pachetelor ARP pe o interfață Ethernet locală
- Urmărirea perechilor de adrese Ethernet/IP
- Raportarea activității și modificărilor suspecte în mapare

Exemple de ARP spoofing tools : ARPWatch: Acest instrument monitorizează activitatea ARP în rețea și emite avertizări sau notificări atunci când detectează activități neobișnuite, cum ar fi schimbări frecvente în tabelele ARP.

- Wireshark: Un instrument de analiză a pachetelor care poate fi utilizat pentru a inspecta traficul ARP și identifica anomalii sau modele suspecte.

16. Mesajul ICMP Echo Request/Reply. Atacul de tip SMURF.

ICMP este folosit pentru a schimba mesaje de control/eroare despre livrarea datagramei IP (pot fi cereri , raspunsuri , mesaje de eroare) .

- Echo request/reply: folosit pentru a testa conectivitatea (ping)

- Mesajele ICMP Echo Request pot fi folosite pentru a mapa host-urile unei rețele (nmap, pingscan sau ipsweep)
- Datagramele ICMP Echo sunt trimise la toate host-urile dintr-o subrețea
- Atacatorul colectează răspunsurile și determină care host-uri sunt active , Echo request poate fi folosit pentru a efectua un atac de denial of service (smurf) .

Etapele atacului (Funcționare):

1. **Spoofing:** Atacatorul trimite un pachet **ICMP Echo Request** (ping). Acesta falsifică adresa IP sursă din antetul pachetului, punând în locul ei **adresa IP a victimei**.
2. **Broadcast:** Pachetul nu este trimis direct către un calculator, ci către **adresa de broadcast** a unei rețele intermediare (numită rețea de amplificare).
3. **Amplificare:** Toate calculatoarele din acea rețea primesc cererea și, conform protocolului, răspund automat cu un **ICMP Echo Reply**.
4. **Inundarea (Flooding):** Deoarece sursa pachetului părea a fi victima, toate aceste răspunsuri sunt direcționate către calculatorul victimei, care este „inundat” de trafic și devine indisponibil.

17. Mesajul ICMP Redirect. Atac de tip ICMP Redirect.

0	4	8	12	16	20	24	28	31
type (5)		code (0-3)		checksum				
IP address of the router that should be used								
IP header + first 8 bytes of the original datagram								

- Câmpul Code

- 0: redirect for networks (obsolete, se folosește redirect de host)
- 1: redirect for hosts

- Un host care primește un mesaj ICMP de redirecționare efectuează următoarele verificări:

- Noul router trebuie să fie pe o subrețea direct conectată
- Redirecționarea trebuie să provină de la routerul curent pentru acea destinație
- Redirecționarea nu poate indica gazdei să folosească propria adresă IP ca router
- Ruta care este modificată trebuie să fie o rută indirectă

- Atacurile **ICMP Redirect** pot fi utilizate pentru a redirecționa traficul pe rute specifice sau către un host specific care nu este un router. • Atacatorul trimite către un host pachete falsificate de tip ICMP Redirect care par să vină de la gateway-ul implicit al host-ului, pentru a face ca traficul să treacă prin intermediul unui dispozitiv compromis.

- Atacul poate fi folosit pentru a: – Deturna (hijack) traficul

- Realiza un atac denial-of-service

Pentru a ne proteja împotriva acestui tip de atac, este important să se implementeze măsuri de securitate, cum ar fi:

- Filtrarea ICMP Redirect

- Verificarea surselor ICMP Redirect: dispozitivele din rețea verifică autenticitatea surselor ICMP Redirect și ignoră mesajele suspecte.

- Monitorizarea traficului ICMP: pentru a detecta modele neobișnuite sau activități suspecte.

- Implementarea autentificării la nivel de rețea

- Actualizarea echipamentelor: cele mai recente actualizări de securitate pentru a remedia eventualele vulnerabilități cunoscute.

18. UDP Spoofing. Hijacking.

UDP • Protocolul UDP se bazează pe IP pentru a furniza un serviciu de livrare de datagrame fără conexiune, nesigur și bazat pe best-effort (livrarea, integritatea, non-duplicarea, ordonarea și lățimea de bandă nu sunt garantate).

- Folosește abstractizarea de porturi, care permite adresarea diferitelor destinații de mesaje cu aceeași adresă IP.

- Este adesea folosit pentru multimedia (mai eficient decât TCP) și pentru servicii bazate pe schemă de cerere/răspuns (DNS, NFS, RPC).

UDP Spoofing se bazează pe ip spoofing, protocolul UDP nu utilizează o conexiune stabilă (nu există un "three-way handshake" ca la TCP), acesta este extrem de vulnerabil la falsificarea identității.

- Reprezintă trimiterea de pachete UDP către o destinație folosind o **adresă IP sursă falsă**.
- **Funcționare:**
 - Atacatorul generează un pachet UDP și inserează în antetul IP (IP header) adresa de internet a unui alt host (victima sau un host de încredere).
 - Deoarece UDP nu verifică dacă destinatarul este gata să primească datele și nici nu confirmă primirea, pachetul este procesat direct de aplicația țintă.
- **Utilizare (Atacuri de amplificare):**
 - UDP Spoofing este baza atacurilor de tip **Fraggle** (varianta UDP a Smurf).
 - Este folosit pentru a păcăli un server (ex: DNS sau NTP) să trimită un răspuns voluminos către adresa falsificată a victimei.

UDP Hijacking : • O formă de atac de tip UDP spoofing • Un atacator care interceptează traficul rețelei ar putea citi pachetele UDP trimise către un server și apoi trimite un răspuns falsificat pentru a părea că vine de la server. Calculatorul va presupune (naiv) că răspunsul falsificat este cel real dacă sosește primul, deoarece nu există nicio modalitate de a verifica identitatea expeditorului.

- La ce poate fi folosit acest lucru? De exemplu, se poate interveni în două dintre protocoalele UDP mai comune: – DNS: Se trimite un răspuns fals la o căutare DNS și se poate păcăli victima să rezolve www.mybank.com într-o adresă IP pe care atacatorul o controlează (un site de phishing). Acest lucru nu va funcționa dacă site-ul este apoi solicitat prin HTTPS, deoarece nu va putea furniza un certificat valid.

- NTP: Trimite valori ale orei false unui client, controlând astfel ceasul său. Acest lucru ar putea fi folosit, de exemplu, pentru a "expira" o logare (dacă timpul este mutat înainte) sau pentru a face un certificat expirat valid (dacă timpul este mutat înapoi).

19. Procesul de rezolvare DNS. Etape.

Procesul de rezolvare (sau interogare) DNS este mecanismul prin care un client obține adresa IP corespunzătoare unui nume de domeniu. Acesta se desfășoară în mai multe etape, implicând diferite tipuri de servere.

- **Etapa 1: Interogarea locală (Cache)**
 - Înainte de a pleca în rețea, calculatorul verifică propria memorie **cache** și fișierul **hosts**. Dacă adresa a fost accesată recent, procesul se oprește aici.
- **Etapa 2: Cererea către DNS Resolver (Recursiv)**

- Dacă IP-ul nu este găsit local, clientul trimite o **interogare recursivă** către serverul DNS configurat (de obicei cel al ISP-ului). Acest server are misiunea de a găsi răspunsul final pentru client.
- **Etapă 3: Interogarea Root Serverelor (.)**
 - Serverul recursiv contactează un **Root Server**. Acesta nu știe adresa IP, dar "știe cine știe" și direcționează cererea către serverele care gestionează terminația domeniului (TLD).
- **Etapă 4: Interogarea Serverelor TLD (Top-Level Domain)**
 - Serverul recursiv întreabă acum serverul **TLD** (ex: pentru **.ro**, **.com** sau **.edu**). Acesta oferă adresa serverului DNS care deține autoritatea peste domeniul respectiv.
- **Etapă 5: Interogarea Serverului Autoritar**
 - Serverul recursiv ajunge în final la **Serverul DNS Autoritar** (cel care găzduiește zona specifică, ex: serverul DNS al ULB Sibiu). Acesta este "sursa adevărului" și oferă adresa IP exactă (ex: **194.169.191.2**).
- **Etapă 6: Returnarea răspunsului și Caching**
 - Serverul recursiv primește IP-ul, îl trimite înapoi la calculatorul utilizatorului și îl salvează și el în memoria cache pentru o perioadă de timp (numită **TTL - Time To Live**), pentru a accelera viitoarele cereri.

20. DNS Poisoning.

DNS Poisoning (Otrăvirea DNS) este un atac prin care date false sunt introduse în memoria cache a unui server DNS, determinând direcționarea utilizatorilor către site-uri malițioase.

- **Context:**
 - Serverele DNS stochează răspunsurile primite în memoria cache (pentru un timp determinat de valoarea TTL) pentru a nu repeta interogările către internet.
 - Atacatorul profită de acest mecanism pentru a înlocui adresa IP legitimă cu una controlată de el.
- **Funcționare (Mecanismul de atac):**
 - **Cererea:** Atacatorul trimite o cerere către un server DNS recursiv pentru un domeniu țintă (ex: **www.banca.ro**).
 - **Interogarea:** Serverul recursiv, neavând adresa în cache, întreabă serverul autoritar prin internet.
 - **Inundarea (Flooding):** În timp ce serverul așteaptă răspunsul legitim, atacatorul trimite mii de răspunsuri false care pretind că vin de la serverul autoritar.
 - **Acceptarea:** Dacă un pachet fals ajunge înaintea celui legitim și are numărul de identificare (Transaction ID) corect ghicit, serverul DNS îl acceptă și îl salvează în cache.
- **Consecințe:**
 - **Redirecționare:** Toți utilizatorii care folosesc acel server DNS vor fi trimiși la site-ul atacatorului, chiar dacă au introdus adresa corectă.
 - **Phishing:** Atacatorul poate colecta date de logare (user/parolă) pe site-ul fals care arată identic cu cel original.
 - **Persistență:** Atacul rămâne activ până când datele "otrăvite" expiră din cache (TTL expiră).

21. VPN. Tehnologii.

Un **VPN (Virtual Private Network)** utilizează conexiuni virtuale (tuneluri) create prin internet pentru a transmite date criptate între un utilizator și o rețea privată sau între două sedii.

Principalele tehnologii utilizate sunt:

1. IPsec (Internet Protocol Security)

Este cel mai utilizat protocol pentru VPN-urile de tip **Site-to-Site** (între două routere/gateway-uri).

- **Nivel:** Lucrează la nivelul 3 (Network), ceea ce înseamnă că securizează tot traficul între punctele terminale, indiferent de aplicație.
- **Componente cheie:**
 - **ESP (Encapsulating Security Payload):** Oferă criptare, autentificare și integritate. Este protocolul care "ascunde" datele.
 - **AH (Authentication Header):** Oferă doar autentificare și integritate (fără criptare).
 - **IKE (Internet Key Exchange):** Gestionează automat negocierea cheilor de securitate.
- **Moduri de funcționare:**
 - **Modul Tunel:** Crijtează întregul pachet IP (folosit în VPN-uri).
 - **Modul Transport:** Crijtează doar datele (payload-ul), păstrând antetul IP original.

2. SSL / TLS (Secure Sockets Layer / Transport Layer Security)

Este tehnologia preferată pentru **Remote Access VPN** (accesul angajaților de acasă).

- **Nivel:** Lucrează la nivelurile superioare (4-7), fiind integrat în browserele web.
- **Avantaje:**
 - **Clientless (Fără client):** Utilizatorul nu trebuie să instaleze software special, folosind doar browser-ul (HTTPS).
 - **Granularitate:** Permite accesul doar la anumite aplicații (ex. doar la mail sau portalul HR), spre deosebire de IPsec care oferă acces la întreaga rețea.
- **Port utilizat:** De regulă, portul **443 (HTTPS)**.

3. Tipuri de VPN (Categorii de implementare)

În funcție de tehnologia aleasă, avem:

- **Site-to-Site VPN:** Conectează rețele întregi (ex: sucursala din Sibiu cu sediul central din București). Se folosește aproape exclusiv **IPsec**.
- **Remote Access VPN:** Conectează utilizatori individuali. Poate fi:
 - **Bazat pe client:** Se instalează o aplicație (ex: Cisco AnyConnect) care poate folosi fie IPsec, fie SSL.
 - **Fără client (Clientless):** Folosește exclusiv **SSL/TLS** prin browser.

22. IPSec. Functiile IPSec.

- IPSec este un standard IETF care definește modul în care o rețea privată virtuală poate fi securizată peste rețele IP.
- IPSec protejează și autentifică pachetele IP între sursă și destinație și oferă aceste funcții esențiale de securitate:
- Confidențialitate - Folosește algoritmi de criptare pentru a împiedica citirea conținutului pachetelor.
- Integritate - Folosește algoritmi de hashing pentru a se asigura că pachetele nu au fost modificate între sursă și destinație.
- Autentificare de origine - Folosește protocolul Internet Key Exchange (IKE) pentru a autentifica sursa și destinația.
- Diffie-Hellman - Folosit pentru a asigura schimbul securizat de chei.

Funcția	Descriere
IPsec Protocol	Opțiunile pentru Protocolul IPsec includ Authentication Header (AH) sau Encapsulation Security Protocol (ESP). AH autentifică pachetul de nivel 3. ESP criptează pachetul de nivel 3. Notă: ESP+AH este rar utilizat deoarece această combinație nu va traversa cu succes un dispozitiv NAT (Network Address Translation).
Confidențialitate	Criptarea asigura confidențialitatea of pachetului de nivel 3. Opțiunile sunt Data Encryption Standard (DES), Triple DES (3DES), Advanced Encryption Standard (AES), sau Software-Optimized Encryption Algorithm (SEAL).
Integritate	Se asigură că datele ajung nealterate la destinație folosind un algoritm de hash, cum ar fi message-digest 5 (MD5) sau Secure Hash Algorithm (SHA).
Autentificare	IPsec utilizează Internet Key Exchange (IKE) pentru autentificarea utilizatorilor și dispozitivelor care pot efectua comunicarea independent. IKE folosește mai multe tipuri de autentificare, inclusiv nume de utilizator și parolă, parolă unică, biometrice, chei pre-partajate (PSK-uri) și certificate digitale folosind algoritmul Rivest, Shamir și Adleman (RSA).
Diffie-Hellman	IPsec folosește algoritmul DH pentru a furniza o metodă de schimb de chei publice pentru ca doi parteneri să stabilească o cheie secretă comună. Există mai multe grupuri diferite din care se poate alege, inclusiv DH14, 15, 16 și DH19, 20, 21 și 24.

- La stabilirea unei legături VPN, partenerii trebuie să partajeze aceeași SA pentru a negocia parametrii de schimbare a cheilor, a stabili o cheie comună, a-și autentifica reciproc și a negocia parametrii de criptare.
- Cele două protocoale principale IPsec sunt AH și ESP, care pot fi aplicate pachetelor IP folosind modul de transport sau modul de tunel.
- Protocolul IKE este un standard de protocol de gestionare a cheilor folosit pentru a negocia automat asociațiile de securitate IPsec și pentru a permite comunicări securizate prin IPsec.
- IKE folosește ISAKMP pentru faza 1 și faza 2 a negocierii cheilor. Faza 1 negociază o asociere de securitate (o cheie) între două perechi IKE. În timpul negocierii fazei 2, IKE stabilește chei (asocieri de securitate) pentru alte aplicații, cum ar fi IPsec.

23. Stateful filtering.

Această abordare permite dispozitivului de securitate să înțeleagă și să aplice reguli pe baza unor criterii mai ample, cum ar fi:

- Urmărirea stării conexiunii: Dispozitivul de filtrare stateful păstrează informații despre starea conexiunilor (stabilirea, închiderea), adresele IP, porturile utilizate, etc.
- Analiza contextuală: Înțelegerea stării conexiunilor permite dispozitivului să evalueze pachetele în contextul conexiunii în curs, poate aplica reguli specifice, cum ar fi permisiuni pentru pachetele asociate unei conexiuni deja stabilite sau pentru răspunsurile la cereri anterioare.
- Gestionarea politicilor de securitate avansate: Prin păstrarea unei stări a conexiunilor, filtrul stateful poate aplica politici de securitate mai avansate, precum permiterea doar a traficului de răspunsuri legate de conexiuni deja stabilite sau blocarea traficului care nu corespunde modelului de comunicare al unei conexiuni valabile.
- Detectarea și prevenirea atacurilor: Capacitatea de a monitoriza starea conexiunilor permite dispozitivului să identifice și să prevină anumite tipuri de atacuri, precum atacurile de tip DoS sau atacuri care încearcă să exploateze slăbiciunile în gestionarea stării conexiunii.
- Filtrarea stateful oferă o securitate robustă în comparație cu filtrarea stateless, permițând dispozitivelor de securitate să aibă o mai bună înțelegere și control asupra traficului în rețea, protejând mai eficient sistemele împotriva unor potențiale amenințări cibernetice.

24. Ce detectează IDS/IPS. Tipuri de IDS/IPS.

IDS (intrusion detection systems) IPS (intrusion prevention systems)

- Sistemele de detecție a intruziunilor (IDS) analizează activitatea rețelei sau a sistemului și detectează semne critice, cum ar fi anomalii în fluxul de date, încercări de acces neautorizat sau alte tipuri de activități neconvenționale care ar putea indica o amenințare.
- Sistemele de prevenire a intruziunilor (IPS) nu numai că detectează activitatea suspectă, ci și iau măsuri active pentru a preveni sau a bloca aceste amenințări. Ele pot opri traficul considerat periculos sau pot izola o parte a rețelei pentru a proteja restul sistemului.

Tipurile specifice de activități sau comportamente pe care sistemul trebuie să le identifice pentru a indica o posibilă intruziune sau amenințare cibernetică:

- Activitate anormală: IDS-ul ar trebui să detecteze activitatea care nu se potrivește cu modelele normale de trafic sau comportament în rețea. Aceasta poate include trafic neașteptat, volum de date neobișnuit sau comportamente de sistem care diferă semnificativ de tiparele normale.
- Atacuri cunoscute: IDS-urile ar trebui să fie capabile să detecteze semnăturile sau modelele de trafic asociate cu atacuri cunoscute. Ele utilizează baze de date de semnături pentru a identifica activitatea care corespunde cu tehnici de atac deja cunoscute și documentate.

- Anomalii de securitate: IDS-urile ar trebui să poată identifica schimbările semnificative în configurarea sistemelor sau în setările de securitate care ar putea indica o posibilă compromitere sau o amenințare de securitate .
- Tentative de penetrare: Detectarea încercărilor de a accesa sisteme sau rețele în mod neautorizat, cum ar fi încercările repetate de login cu parole greșite sau explorarea vulnerabilităților de securitate.
- Trafic suspect sau neobișnuit: Identificarea traficului care poate fi asociat cu utilizarea sau exploatarea de software rău intenționat, cum ar fi viruși, malware sau alte instrumente folosite în atacuri cibernetice.

Tipurile sunt : Host-based

- Monitorizează activitatea pe un singur host.
- Avantaj: o vizibilitate mai bună asupra comportamentului aplicațiilor individuale care rulează pe host.

Network-based (NIDS)

- De obicei plasat pe un router sau un firewall.
- Monitorizează traficul, examinează antetele și încărcăturile pachetelor.
- Avantaj: un singur NIDS poate proteja multe host-uri și poate căuta modele globale.

25. Tehnici de detecție IPS/IDS.

IDS/IPS bazat pe semnături:

- Aceste sisteme utilizează baze de date de semnături pentru a identifica și a bloca atacurile cunoscute.
- Ele compară tiparele de trafic sau comportamentul sistemului cu semnăturile cunoscute ale atacurilor pentru a detecta amenințările.
- În cazul IPS, acestea pot acționa automat pentru a bloca sau a preveni atacurile identificate.

IDS/IPS bazat pe anomalii:

- Acest tip de sistem monitorizează activitatea rețelei sau a sistemului în timp real și identifică comportamente neobișnuite sau anormale.
- În loc să se bazeze pe semnături specifice de atac, aceste sisteme compară activitatea actuală cu modelele normale de trafic sau comportament pentru a detecta abaterile care ar putea indica o amenințare.

IDS/IPS bazat pe euristică:

- Aceste sisteme folosesc reguli și algoritmi complecși pentru a identifica potențialele amenințări, utilizând logica și înțelegerea comportamentului tipic al atacatorilor.

- Ele nu se bazează strict pe semnături specifice, ci pe modele de comportament suspect.

IDS/IPS bazat pe fluxuri de date:

- Aceste sisteme analizează fluxurile de date în loc să se concentreze pe pachete individuale.
- Ele monitorizează traficul continuu și pot detecta anomalii în fluxurile de date care ar putea indica o potențială intruziune.

Misuse detection

- Folosirea "semnăturilor" atacului (necesită un model al atacului).
- Secvențe de apeluri de sistem, modele de trafic de rețea, etc..
- Trebuie să știe în avans ce va face atacatorul (cum?).
- Poate detecta doar atacuri cunoscute.

Anomaly detection

- Utilizând un model al comportamentului normal al sistemului, încearcă să detecteze abateri și anormalități.
- De exemplu, declanșează o alarmă când apare un eveniment statistic rar.
- Poate detecta potențiale atacuri necunoscute.

26. ACL vs Capabilități (Drepturi de acces).

Liste de Control al Accesului:

- Se concentrează pe resurse.
- Sunt utile dacă resursele sunt mult mai numeroase decât utilizatorii.
- Pot fi atașate la obiecte (de exemplu, metadatele unui fișier).
- Sunt eficiente atunci când utilizatorul care creează o resursă are autoritate asupra ei.

Sistem de Capabilități:

- Se concentrează pe utilizatori.
- Sunt utile dacă utilizatorii sunt mult mai numeroși decât resursele.
- Sunt eficiente atunci când un manager de sistem are control asupra tuturor resurselor.
- Liste de Control al Accesului pentru fișiere și alte resurse.
- Capabilități pentru funcțiile majore ale sistemului.

Sistemele de operare comune oferă AMBELE.

- Linux pune accentul pe un model ACL.
 - Oferă un control asupra fișierelor și resurselor asemănătoare fișierelor.
- Windows pune accentul pe Capabilități.
 - Oferă control bun asupra accesului la funcțiile sistemului (de exemplu, crearea unui nou utilizator).
 - Liste de control al accesului pentru fișiere.

Sistemul de operare trebuie să se asigure că matricea de acces nu este modificată (sau chiar accesată) într-un mod neautorizat.

Liste de control de acces

- Citirea sau modificarea ACL-ului este un apel de sistem.
- Sistemul de operare se asigură că operația dorită este permisă.

Liste de capabilități

- Pot fi gestionate în același mod ca și ACL-urile: citirea și modificarea sunt făcute de către sistemul de operare.
- Pot fi transmise proceselor și verificate criptografic ulterior.
- Utile în sistemele distribuite în care capabilitățile nu pot fi verificate centralizat.

27. Modelul Bell-La Padula.

- Proprietatea de securitate simplă: Această proprietate se referă la capacitatea unui proces de a accesa informații în funcție de nivelul său de securitate. Conform acestei proprietăți, un proces la nivelul "k" poate citi doar obiecte la niveluri "k" sau mai joase. Aceasta împiedică informațiile să se deplaseze de la niveluri superioare la niveluri inferioare.
- Proprietatea * (star): Această proprietate reprezintă o restricție suplimentară asupra scrierii în sistemul de securitate. Un proces la nivelul "k" poate scrie doar în obiecte la nivele "k" sau mai mari. Această proprietate ajută la prevenirea scurgerilor de informații de la niveluri inferioare către niveluri superioare.
- Aceste două proprietăți de securitate, împreună, contribuie la asigurarea confidențialității și integrității datelor într-un sistem securizat.
- Ele controlează fluxul de informații și previn accesul neautorizat sau modificările la niveluri de securitate inadecvate, asigurând că informațiile sensibile sunt protejate și nu sunt divulgate către entități neautorizate.
- Modelul Bell-LaPadula este adesea asociat cu clasificările de tip militar, unde informațiile sunt împărțite în niveluri de securitate diferite (cum ar fi confidențial, secret, top secret etc.), iar accesul este controlat în funcție de aceste niveluri.

- Modelul Bell-LaPadula combină două tipuri de control al accesului:

- Controlul accesului obligatoriu: Se referă la reguli stricte și obligatorii care se aplică în funcție de nivelurile de securitate. Proprietatea de confidențialitate (citit și scris) este impusă prin aceste reguli.

- Controlul accesului discreționar: Acesta se referă la permisiunile care sunt la discreția utilizatorilor sau entităților deținătoare de informații, permițându-le să acorde sau să restricționeze accesul la informații.

28. Pașii unei investigații digitale.

Potrivit multor profesioniști, Digital Forensics este un proces în patru pași:

- Achiziție

Obținerea fizică sau de la distanță a posesiei asupra sistemului, a tuturor mapărilor de rețea din sistem și a dispozitivelor externe de stocare fizică.

- Identificare

Acest pas implică identificarea datelor care ar putea fi recuperate și recuperarea electronică a acestora, rulând diverse instrumente software.

- Evaluare

Evaluarea informațiilor/datelor recuperate pentru a determina dacă și cum ar putea fi folosite împotriva suspectului în caz de proces judiciar.

- Prezentare

Acest pas implică prezentarea probelor descoperite într-un mod înțeles de avocați, personal/management non-tehnic și adecvat ca probă conform legilor.

Se recomandă următorii 16 pași în procesarea probelor.

- Pasul 1: Se oprește sistemul.

- Se iau în considerare informațiile volatile!

- Se previne accesul de la distanță la sistem și distrugerea probelor.

- Pasul 2: Se documentează configurația hardware a sistemului.

- Se notează totul despre configurație înainte de relocare.

- Pasul 3: Se transportă sistemul într-o locație sigură.

- Nu lăsa computerul nesupravegheat decât dacă este stocat într-o locație sigură.

- Pasul 4: Se realizează copii bit la bit ale discurilor.

- Pasul 5: Se autentifică datele de pe toate dispozitivele de stocare.

– Trebuie să se poată demonstra că nu au fost modificate niciuna dintre probe după ce sistemul a fost ridicat. Se calculează hashuri.

- Pasul 6: Se documentează data și ora sistemului.
- Pasul 7: Se face o listă cu cuvintele cheie de căutare.
- Pasul 8: Se evaluează fișierul/partiția de swap.
- Pasul 9: Se evaluează "file slack". File slack este o zonă de stocare a datelor ce poate reprezenta o sursă de scurgeri de securitate.
- Pasul 10: Se evaluează spațiul nealocat (fișiere șterse).
- Pasul 11: Se caută cuvinte cheie în fișiere, file slack și spațiul nealocat.
- Pasul 12: Se documentează numele fișierelor, datele și orele.
- Pasul 13: Se identifică anomalii în fișiere, programe și stocare.
- Pasul 14: Se evaluează funcționalitatea programelor găsite.
- Pasul 15: Se documentează tot ce a fost găsit.
- Pasul 16: Se păstrează copii ale software-ului utilizat.

29. Metode de ascundere a datelor.

Manipularea sistemului de fișiere și a hard disk-ului

Spațiul Slack

- Reprezintă spațiul dintre sfârșitul logic și sfârșitul fizic al unui fișier și este numit spațiul slack al fișierului.
- Sfârșitul logic al unui fișier vine înainte de sfârșitul fizic al clusterului în care este stocat.
- Octeții rămași în cluster sunt resturi ale fișierelor sau directoarelor anterioare stocate în acel cluster.
- Spațiul slack poate fi accesat și scris direct folosind un editor de disc în hexazecimal.
- Acest lucru nu modifică informația despre "spațiul utilizat" pe disc.

Partition waste space

- Spațiul nefolosit al unei partiții este zona de pe discul unde nu sunt stocate date sau informații. Această zonă nefolosită poate fi rezultatul faptului că sistemul de fișiere rezervă spațiu suplimentar pentru a facilita operarea sau poate fi spațiu rămas neutilizat după crearea sau modificarea partiției.
- Dacă datele sensibile sunt șterse sau mutate în această zonă a discului, există riscul ca aceste informații să rămână acolo chiar și după ștergere. În cazul în care o partiție conține date critice și acestea sunt mutate sau șterse în spațiul nefolosit al acelei partiții, aceste

informații ar putea fi recuperate în mod neintenționat de către atacatori sau persoane neautorizate.

Hidden drive space

- Spațiul ascuns de pe disc care nu este atribuit niciunei partiții, poate fi folosit pentru a ascunde date.
- Pentru a scrie/citi date din acest spațiu, trebuie să fie cunoscute adresele sectoarelor.

Bad sectors

- Sectoarele defecte apar atunci când sistemul de operare încearcă să citească informații dintr-un sector fără succes. După un număr de încercări nereușite, sistemul copiază (dacă este posibil) informațiile în alt sector și marchează sectorul ca fiind defect.
- Utilizatorii pot controla marcarea sectoarelor defecte și folosite pentru a ascunde date.

Schimbarea numelui de fișier și a extensiei

- Redenumirea cu un nume specific sistemului de operare și a extensiei din .doc în .dll pentru un fișier care se dorește a nu fi găsit și citit.

30. Politica de logging.

- Este un set de reguli și directive care stabilesc modul în care datele sunt înregistrate, gestionate și utilizate într-o organizație.
- Aceste politici sunt esențiale pentru a asigura o înregistrare eficientă, securizată și conformă a datelor și a activităților.

Elemente incluse în politica de logging:

- Scopul și obiectivele: Definirea motivelor pentru care înregistrările sunt efectuate. Acest lucru poate include conformitatea legală, securitatea informațiilor, auditarea și monitorizarea activităților.
- Tipurile de date înregistrate: Precizarea tipurilor de date care vor fi înregistrate, cum ar fi evenimente de securitate, tranzacții financiare, interacțiuni ale utilizatorilor sau activitatea sistemului.
- Perioada de retenție: Stabilirea perioadei pentru care datele vor fi păstrate înainte de a fi șterse sau arhivate. Acest lucru poate fi determinat de cerințe legale, politic interne sau necesități practice.
- Accesul și securitatea: Definirea a cine are permisiunea de a accesa și gestiona înregistrările, precum și măsurile de securitate necesare pentru a proteja datele împotriva accesului neautorizat sau a modificărilor.
- Procesele de înregistrare: Specificarea procedurilor și instrumentelor utilizate pentru înregistrare, formatarea și stocarea datelor înregistrate.
- Monitorizarea și revizuirea: Stabilirea unui proces pentru monitorizarea și revizuirea înregistrărilor pentru a asigura respectarea politicilor și pentru a identifica potențiale anomalii sau probleme de securitate.

– Notificări și raportare: Definirea modului în care vor fi gestionate notificările și rapoartele generate din înregistrări pentru a informa părțile interesate despre incidente sau activități semnificative.

– Actualizări și revizuiți: Planificarea revizuirilor periodice și actualizărilor politicii de înregistrare pentru a ține pasul cu schimbările tehnologice, reglementările și cerințele organizației.

- O politică de înregistrare bine definită și implementată corespunzător este esențială pentru protejarea datelor sensibile, menținerea conformității și asigurarea unei bune practici în gestionarea informațiilor într-o organizație.

- Politica de logging poate depinde de:

- Spațiul pe stocare disponibil.

- Nivelul de securitate care se dorește a fi implementat.

- Indiferent de schemă selectată, întreținerea regulată a fișierelor de log trebuie să fie automatizată folosind serviciul cron.

- NU se recomandă stergerea log-urilor din următoarele motive:

- Probleme de securitate (datele contabile și fișierele de log oferă dovezi importante ale încălcărilor).

- Alerte cu privire la problemele de hardware și software.

31. Penetration Testing. Etape. Descriere.

“Penetration Testing este o metodă de a simula tehnicile pe care un atacator le-ar putea folosi pentru a ocoli controalele de securitate și pentru a obține acces la un sistem.”

Etape :

1. Colectarea prealabilă de informații

- Această etapă implică colectarea informațiilor despre sistemul sau organizația țintă înainte de a începe o evaluare sau testare de securitate. Include înțelegerea infrastructurii organizației, a tehnologiei, a posibilelor slăbiciuni și a informațiilor disponibile public care ar putea fi relevante.

- Se discută sfera și termenii testului de penetrare cu clientul, despre ce se va întâmpla, așteptările unui test de penetrare, ce va fi testat, necesitatea unui acces total pentru a obține un raport complet.

- Se adună informații despre organizație (social media, Google, etc.).

- Se încercă explorarea organizației pentru porturi care pot fi blocate (se folosește o adresă IP de unică folosință, deoarece aceasta va fi blocată dacă este activată scanarea de porturi).

- Se testează aplicațiile web.

- Notă: se recomandă a se efectua scanări dintr-un interval de adrese IP care nu pot fi trasate înapoi către locația de unde se face testul.

2. Modelarea amenințărilor

- Analistii creează un model care identifică amenințările potențiale, vulnerabilitățile și posibili vectori de atac care ar putea afecta sistemul. • Acest lucru implică analizarea arhitecturii sistemului și identificarea posibilelor slăbiciuni pe care atacatorii le-ar putea exploata.
- Se folosesc informațiile obținute în etapa anterioară.
- Se analizează organizația ca și cum ați fi un adversar și se determină:
 - de unde ar putea veni amenințările,
 - ce formă ar putea lua,
 - ce urmăresc acestea.

3. Analiza vulnerabilităților

- În această etapă, sistemul este supus unei examinări detaliate pentru a identifica și evalua vulnerabilitățile.
- Acest lucru include utilizarea uneltelor și tehnicilor pentru a scana slăbiciunile software-ului, ale rețelei, configurațiilor sau altor componente.
- Se vor folosi toate informațiile din fazele precedente. Se va face o analiză detaliată care ia în considerare scanările de porturi și vulnerabilități.

4. Exploatare

- Partea „strălucitoare” a testului de penetrare.
- Se folosește “brute force” (nu foarte “elegant”) în loc de acțiuni de precizie.
- Separă testerii „buni” de cei „răi”:
 - Testerii „răi” vor lansa un atac masiv de exploit-uri.
 - Testerii „buni” vor utiliza doar exploit-uri așteptate să reușească pe baza informațiilor adunate.
- Crearea de “zgomot” cu exploit-uri masive și speranța pentru un rezultat, nu este modul de abordare corect!

5. Post exploatare

- După obținerea accesului, explorarea suplimentară a sistemului pentru a menține controlul sau pentru a identifica și a exploata alte posibile slăbiciuni.
- După ce au fost compromise unul sau mai multe sisteme:
 - Se vizează anumite sisteme critice,
 - Se identifică infrastructura critică,

- Se vizează informațiile sau datele de valoare pentru companie.
- Se începe cu sistemele care vor avea cel mai mare impact asupra companiei în cazul unei breșe de securitate.
- Se determină tipul și rostul sistemelor și ce roluri au diferiți utilizatori.
- Spre exemplu:
 - Dacă a fost compromis un server web. Nu e mare lucru...
 - Dar, s-ar putea aduna informații despre celelalte sisteme utilizate de companie, un backdoor ascuns într-o aplicație financiară sau sistemul de salarizare sau date de proprietate intelectuală.

6. Raportare

- Documentarea tuturor constatărilor, inclusiv a vulnerabilităților descoperite și a recomandărilor pentru remediere, într-un raport comprehensiv care este oferit organizației respective pentru a remedia problemele identificate.
- Este instrumentul principal prin care clienții pot îmbunătăți și consolida securitatea sistemului sau organizației lor.
- Raportarea în testele de penetrare este esențială pentru a oferi o imagine completă a situației de securitate și pentru a facilita procesul de remediere a problemelor identificate.
- Include cel puțin:
 - Sumar executiv: O prezentare succintă și accesibilă pentru persoanele la nivel executiv, care evidențiază concluziile, riscurile majore și măsurile recomandate pentru remedierea acestora.
 - Constatări tehnice: Detalii complete despre toate vulnerabilitățile, metodele de atac folosite, descrieri ale exploatărilor și orice alte informații relevante descoperite în timpul testului de penetrare.
 - Recomandări pentru remediere: O listă clară și detaliată a acțiunilor care trebuie întreprinse pentru a remedia fiecare vulnerabilitate sau problemă de securitate identificată. Aceste recomandări ar trebui să fie practice și ușor de pus în aplicare.
 - Riscuri și impact: Evaluarea riscurilor asociate fiecărei vulnerabilități sau constatări, inclusiv impactul potențial al exploatării acestora asupra sistemului sau organizației.
 - Sfaturi și concluzii: Sfaturi generale sau concluzii din partea echipei de securitate pentru a ghida clientul în procesul de remediere și pentru a ajuta la prioritizarea acțiunilor.
 - Prezentare și explicare: În plus față de documentul scris, o prezentare sau o întâlnire pentru a explica și a discuta constatările și recomandările cu echipele de conducere și de tehnologie.

32. Tipuri de malware.

Malware, prescurtare de la software rău intenționat, apare în diferite forme, fiecare proiectat să infecteze sau să deterioreze un sistem fără consimțământul utilizatorului. Unele dintre cele mai comune tipuri:

1. Virus: Un program rău intenționat care, odată executat, se replică modificând alte programe și inserând propriul său cod.
2. Worm: Un program autonom care se replică pentru a se răspândi la alte calculatoare. De multe ori folosește o rețea pentru a se răspândi, bazându-se pe găuri de securitate ale calculatorului țintă pentru a-l accesa.
3. Trojan: Un tip de malware care este deseori deghizat în software legitim. Troienii pot fi folosiți de către hoți și hackeri care încearcă să obțină acces la sistemele utilizatorilor.
4. Spyware: Software care permite unui utilizator să obțină informații secrete despre activitățile altui calculator prin transmiterea datelor pe ascuns de pe hard drive-ul acestuia.
5. Adware: Reclame livrate automat. Este o formă de malware atunci când este implementată cu intenții și acțiuni rău intenționate, cum ar fi urmărirea și furtul de date.
6. Ransomware: Un tip de malware din criptovirologie care amenință să publice datele victimei sau să blocheze permanent accesul la acestea, dacă nu se plătește o răscumpărare.
7. Rootkit: Un program sau o colecție de instrumente software care oferă unei persoane acces la distanță și control asupra unui sistem.
8. Keylogger: Un tip de tehnologie de supraveghere utilizată pentru a înregistra apăsările de taste. Keylogger-urile pot fi utilizate în organizații IT pentru a depana problemele tehnice ale calculatoarelor și rețelelor.
9. Botnet: Un număr de dispozitive conectate la Internet, fiecare dintre acestea executând unul sau mai mulți boți. Botnet-urile pot fi folosite pentru a efectua atacuri de tip Distributed Denial-of-Service (DDoS), furt de date, trimitere de spam și permite atacatorului să acceseze dispozitivul și conexiunea sa.
10. Logic Bomb: Un fragment de cod inserat intenționat în software pentru a efectua o funcție rău intenționată atunci când sunt îndeplinite anumite condiții.
11. Backdoor: O tehnică prin care mecanismul de securitate al unui sistem este ocolit în mod nedetectabil pentru a accesa un calculator sau datele acestuia.
12. Exploit: Un fragment de software, un chunk de date sau o secvență de comenzi care profită de un bug sau vulnerabilitate pentru a cauza un comportament neintenționat sau neașteptat.

33. Etapele raspandirii malware-ului.

- Virușii sunt programe scrise în mare parte în limbaj de asamblare.
- Etapele prin care pot compromite și a afecta funcționarea normală a sistemelor:

1. Infiltrarea: Virușii pătrund într-un sistem prin intermediul unor surse infectate, cum ar fi descărcările de pe internet, e-mailurile sau dispozitivele de stocare infectate (stick-urile USB).
2. Reproducerea: După ce infectează un sistem, virușii pot începe să se reproducă și să se răspândească. Ei pot atașa copii ale lor în alte fișiere sau pot infecta alte dispozitive din rețea.
3. Activarea: Odată ce sunt activi, virușii pot declanșa acțiuni ce pot varia de la coruperea datelor până la furtul de informații sensibile sau chiar preluarea controlului asupra sistemului infectat.
4. Ascunderea: Pentru a evita detectarea și eliminarea, virușii pot încerca să se ascundă în fișiere de sistem sau să modifice comportamentul normal al sistemului pentru a evita detectarea.
5. Răspândirea: Unele tipuri de viruși sunt proiectate pentru a se răspândi pe scară largă, infectând cât mai multe dispozitive posibil. Ei pot profita de vulnerabilități cunoscute în software sau pot exploata erori de securitate pentru a se extinde.
6. Distrugerea sau Controlul: În funcție de tipul lor, virușii pot avea obiective diferite, de la coruperea datelor la preluarea controlului asupra sistemului infectat sau chiar distrugerea acestuia.

34. Steganografie. Criptografie. Cifrul lui Cesar.

Steganografie:

- Provine din cuvintele grecești "steganos" (acoperit) și "graphie" (scriere), având sensul de "scriere acoperită".
- Scopul principal al steganografiei este ascunderea existenței unui mesaj într-un alt mediu (cum ar fi o imagine, fișier audio sau text) într-un mod care nu este evident pentru un observator.
- Steganografia depinde de menținerea secretului metodei de ascundere a mesajului. Securitatea mesajului se bazează pe confidențialitatea tehnicii utilizate pentru înglobarea sau ascunderea informației.

Criptografie:

- Termenul "criptografie" provine din cuvintele grecești "kryptos" (ascuns) și "graphie" (scriere), având sensul de "scriere ascunsă".
- Criptografia se concentrează asupra ascunderii sensului unui mesaj prin utilizarea algoritmilor și tehnicilor matematice. Ideea este de a face mesajul iligibil pentru oricine nu deține cheia sau cunoștințele adecvate.
- Spre deosebire de steganografie, criptografia depinde de confidențialitatea unei chei, în loc să păstreze secretă metoda de criptare. Securitatea mesajului se bazează pe dificultatea descifrării mesajului fără cheia corectă.

Cifrul lui Cesar : • O metodă simplă de criptare și decriptare cu un spațiu de chei [0..25], unde fiecare literă din textul clar este înlocuită cu litera de pe poziția corespunzătoare din alfabet (deplasată spre dreapta pentru criptare, spre stânga pentru decriptare).

- Această metodă amintește de cifrul lui Cezar, unde cheia ($K=3$) reprezintă numărul de poziții cu care fiecare literă este deplasată.
- Poate un atacator să găsească K ? Printr-un atac de căutare exhaustivă a cheilor. Spațiul cheilor este mic (≤ 26).
- Concluzie: Spațiul de chei trebuie să fie destul de mare.

Căutarea exhaustivă a cheilor poate fi eficientă.

35. Cifrul cu substituție mono-alfabetică.

- Spațiul cheilor: toate permutările lui $\Sigma = \{A, B, C, \dots, Z\}$.
- Criptarea cu o cheie π : fiecare literă X din textul clar P este înlocuită cu $\pi(X)$.
- Decriptarea cu o cheie π : fiecare literă Y din textul criptat P este înlocuită cu $\pi^{-1}(Y)$.
- Exemplu:

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
$\pi =$	B	A	D	C	Z	H	W	Y	G	O	Q	X	S	V	T	R	N	M	L	K	J	I	P	F	E	U

CIFRU se criptează DGHMJ

- Căutarea exhaustivă este dificilă deoarece dimensiunea spațiului cheilor este $26! \approx 4 \times 10^{26} \approx 288$
- Domină arta scrisului secret pe parcursul primului mileniu d.Hr.
- Se credea că este impenetrabil de către mulți în acea perioadă.
- Poate fi spart?

da , • Fiecare limbă are anumite caracteristici: frecvența literelor sau a grupurilor de două sau mai multe litere.

- Cifrurile de substituție păstrează caracteristicile limbii.
- Cifrurile de substituție sunt vulnerabile la atacuri de analiză a frecvențelor.
- Frecvența literelor în limba engleză.

36. Cifrul cu substituție poli-alfabetică. Cifrul Vigenère.

Principalele slăbiciuni ale cifrurilor de substituție mono-alfabetică:

- În textul criptat, diferite litere au frecvențe diferite.
- Fiecare literă în textul criptat corespunde doar unei litere în textul clar.

Alberti a avut o idee pentru un cifru mai puternic (anii 1460):

- Se utilizează mai multe substituții și se schimbă în timpul criptării pentru diferite litere.
- Ca rezultat, frecvențele literelor în textul criptat sunt similare.
- Vigenère a dezvoltat un cifru ușor de utilizat (publicat în 1586).

- Se tratează literele ca numere: $[A=0, B=1, C=2, \dots, Z=25]$
- Notarea numerelor: $Z_n = \{0, 1, \dots, n-1\}$
- Definiție: Dat fiind m , un întreg pozitiv, $P = C = (Z_{26})^n$ și $K = (k_1, k_2, \dots, k_m)$ o cheie, definim:
- Criptarea:

$$e_k(p_1, p_2 \dots p_m) = (p_1+k_1, p_2+k_2 \dots p_m+k_m) \pmod{26}$$

- Decriptarea:

$$d_k(c_1, c_2 \dots c_m) = (c_1-k_1, c_2-k_2 \dots c_m-k_m) \pmod{26}$$

- Exemplu:

Text clar:	C R Y P T O G R A P H Y
Cheie:	L U C K L U C K L U C K
Text criptat:	N L A Z E I I B L J J I

- Cifrul Vigenere maschează frecvența cu care apare un caracter într-o limbă: o literă în textul criptat corespunde mai multor litere în textul clar.

- Face utilizarea analizei de frecvență mai dificilă.

- Orice mesaj criptat cu ajutorul cifrului Vigenere este o colecție de cifruri Caesar câte numere de litere se află în cheie.

- Criptoanaliza cifrului Vigenere implică în mod tipic încercarea de a determina lungimea cheii și apoi de a decripta mesajul prin găsirea literelor individuale ale cheii.

- Testul Kasiski: Una dintre tehnicile comune pentru spargerea cifrului Vigenere este Testul Kasiski. Această metodă implică căutarea de modele repetitive în textul criptat care pot indica lungimea cheii.

37. One-Time Pad.

"One-Time Pad" (OTP) este un sistem de criptare care, dacă este utilizat corect, oferă un nivel teoretic de securitate perfectă. Acesta funcționează prin combinarea fiecărui bit sau caracter din mesajul clar (textul original) cu un bit sau caracter dintr-o cheie secretă (pad) aleatoare și de aceeași lungime.

Principalele caracteristici ale One-Time Pad sunt următoarele:

1. Cheia Aleatoare și de Aceeași Lungime: Cheia trebuie să fie complet aleatoare și să aibă aceeași lungime ca mesajul care trebuie criptat. Datorită acestui fapt, fiecare bit sau caracter din mesaj este mascat complet prin combinarea cu un bit sau caracter din cheie.
2. Utilizare unică a Cheii: Cheia utilizată pentru criptarea unui mesaj trebuie să fie unică și să nu fie folosită din nou pentru alte mesaje. Aceasta este sursa termenului "one-time" (o singură utilizare).
3. Securitate Perfectă: Datorită naturii aleatoare a cheii și faptului că este folosită o singură dată, One-Time Pad este considerat a oferi securitate perfectă. Nu există niciun mod practic de a sparge cifrul fără cunoașterea cheii, deoarece fiecare posibil text clar este la fel de probabil.
4. Criptare și Decriptare: Procesul de criptare implică combinarea textului clar cu cheia folosind o operație simplă, cum ar fi XOR (exclusive OR). Procesul de decriptare inversă se realizează prin aplicarea aceleiași operații între textul criptat și cheia.
5. Limitări Practice: În ciuda securității sale teoretice, One-Time Pad este limitat în utilizarea practică deoarece necesită chei de aceeași lungime ca mesajele, ceea ce face generarea, distribuirea și păstrarea cheilor un proces dificil și adesea impracticabil pentru utilizare la scară largă.

Datorită acestor caracteristici, One-Time Pad este un exemplu remarcabil în teoria criptografiei, dar utilizarea sa este limitată în aplicații practice.

38. Integritatea datelor și autentificare. Funcții hash.

Integritatea datelor și autentificarea sunt concepte esențiale în securitatea informațiilor, iar funcțiile hash criptografice joacă un rol crucial în aceste procese:

1. Funcții Hash pentru Integritatea Datelor: Funcțiile hash sunt utilizate pentru a verifica dacă datele au fost modificate. O funcție hash simplă poate mapa șiruri de caractere la numere întregi și poate fi folosită pentru a verifica integritatea datelor. Dacă valoarea hash a datelor se schimbă, este posibilă o modificare a datelor.

Funcțiile de hash sunt de asemenea folosite pentru stocarea sigură a parolilor, stocând valoarea hash a acestora în loc să le stocheze în forma originală.

2. ****Caracteristici ale Funcțiilor Hash****: O funcție hash mapează un mesaj de lungime arbitrară la o ieșire de lungime fixă, cunoscută sub numele de amprentă sau rezumatul mesajului (digest). Caracteristicile esențiale ale unei funcții hash bune includ:

- ****Determinism****: Aceeași intrare va produce întotdeauna aceeași ieșire.
- ****Eficiență****: Calculul valorii hash trebuie să fie rapid și eficient.

- ****Ireversibilitate****: Din valoarea hash nu trebuie să se poată recupera intrarea inițială.

3. ****Rezistența la Coliziuni****: O funcție hash $h: X \rightarrow Y$ este considerată rezistentă la coliziuni (strong collision resistant) dacă este computațional dificil să găsești două valori distincte x și x' în X astfel încât $h(x) = h(x')$. Ar trebui să fie dificil să găsești două intrări care produc aceeași valoare de hash.

Aceste caracteristici ale funcțiilor hash sunt fundamentale pentru asigurarea integrității datelor și pentru procesul de autentificare în sistemele de securitate cibernetică.

Functii Hash : MD5 (Message Digest Algorithm 5): Produce o valoare hash de 128 de biți. Nu este recomandat pentru utilizare criptografică din cauza vulnerabilităților.

- SHA-1 (Secure Hash Algorithm 1): Produce o valoare hash de 160 de biți. Dezaprobată pentru utilizare criptografică din cauza vulnerabilităților.

- SHA-256, SHA-384, SHA-512 (Secure Hash Algorithms): Fac parte din familia SHA-2 și produc valori hash de 256, 384 și 512 biți, respectiv.

Utilizate pe scară largă în aplicații criptografice.

Whirlpool: Produce o valoare hash de 512 biți. Proiectată pentru a oferi un nivel ridicat de securitate.

- RIPEMD-160 (RACE Integrity Primitives Evaluation Message Digest):

Produce o valoare hash de 160 de biți. Dezvoltată ca alternativă la MD5 și SHA-1, care sunt pe scară largă utilizate, dar vulnerabile.

- BLAKE2: Funcție de hash criptografică mai rapidă decât MD5, SHA-1, SHA-2 și SHA-3. Disponibilă în diferite configurații.

- Skein: Unul dintre finaliștii din competiția funcțiilor de hash NIST (competiția SHA-3). Proiectată să fie rapidă și sigură.

- Keccak: Câștigătoare a competiției NIST pentru funcții de hash, devenind SHA-3. Oferă lungimi flexibile ale rezultatelor și nivele de securitate.

39. Proprietățile funcțiilor de hash.

Funcțiile hash criptografice au proprietăți importante care asigură securitatea și integritatea datelor. Iată cele mai esențiale:

1. **Determinism** : Aceeași intrare va produce întotdeauna aceeași ieșire. Acest lucru înseamnă că orice modificare, chiar și minoră, a datelor de intrare va rezulta într-o valoare hash complet diferită .

2. **Eficiență** : Calculul valorii hash trebuie să fie rapid și eficient, permițând procesarea rapidă a datelor mari fără întârzieri semnificative .

3. **Ireversibilitate** : Din valoarea hash nu trebuie să se poată recupera intrarea inițială. Acest lucru înseamnă că funcțiile hash sunt concepute să fie unidirecționale, ceea ce face practic imposibilă deducerea datelor originale din valoarea hash .

4. Rezistență One-way:

– O funcție hash $h: X \rightarrow Y$ este considerată rezistentă la preimagine (one-way) dacă, dat fiind $y \in Y$, este computațional dificil să găsești o valoare $x \in X$ astfel încât $h(x) = y$.

– Ar trebui să fie dificil să se inverseze procesul și să se determine intrarea originală din valoarea de hash.

5. Rezistență la Weak Collision (A Doua Preimagine) : Este computațional dificil să găsești o valoare x' diferită de x dată, astfel încât $h(x') = h(x)$. Aceasta înseamnă că este dificil să găsești o intrare diferită care produce aceeași valoare de hash pentru o intrare dată.

6. Rezistență la Coliziuni (Strong Collision) : Este computațional dificil să găsești două valori distincte x și x' astfel încât $h(x) = h(x')$. Acest lucru înseamnă că este foarte improbabil să găsești două intrări diferite care produc aceeași valoare hash.

Aceste proprietăți fac funcțiile hash criptografice instrumente esențiale pentru asigurarea integrității datelor și autentificării în sistemele de securitate informatică.

40. Message Authentication Code.

Message Authentication Code (MAC) este un sistem folosit pentru autentificarea mesajelor. Iată cum funcționează și principalele sale caracteristici:

1. ****Definiția MAC****: MAC este o familie de funcții de hash utilizată pentru autentificarea mesajelor. Calculul MAC pentru un mesaj M se face folosind o cheie K , unde H_K este funcția de hash asociată cheii K . Acesta indică faptul că pentru fiecare cheie K și mesaj X există un rezumat de mesaj Y asociat.

2. ****Utilizarea Cheii Secretă Comune****: Atât expeditorul, cât și destinatarul mesajului folosesc aceeași cheie secretă K . Expeditorul trimite mesajul M împreună cu MAC-ul corespunzător, calculat folosind cheia comună K .

3. ****Verificarea și Acceptarea Mesajului****: La primirea mesajului (X, Y) , destinatarul verifică dacă $H_K(X) = Y$. Dacă această verificare este reușită, destinatarul acceptă mesajul ca provenind de la expeditor.

4. ****Securitatea Sistemului MAC****: Securitatea într-un sistem MAC implică faptul că un adversar nu ar trebui să poată produce un alt mesaj X' împreună cu un MAC valid Y' fără a cunoaște cheia secretă K . Acest lucru asigură că nu poate fi creat un MAC valid pentru un mesaj arbitrar fără cheia secretă, oferind astfel integritate și autentificare pentru mesajele transmise.

MAC este astfel un instrument esențial în asigurarea integrității și autentificării mesajelor în comunicațiile securizate.

41. Protocolul de distribuție de chei Diffie-Hellman.

Protocolul de distribuție de chei Diffie-Hellman este o metodă de stabilire a unei chei secrete comune între două părți, prin intermediul unui canal de comunicare nesigur. Acest protocol, introdus de Whitfield Diffie și Martin Hellman în 1976, este utilizat pe larg în diverse aplicații criptografice, inclusiv în securizarea comunicațiilor pe internet și în stabilirea cheilor pentru criptarea simetrică.

Iată cum funcționează protocolul:

1. **Alegerea Parametrilor Comuni**: Două părți, adesea denumite Alice și Bob, convin asupra unor parametri publici partajați, cum ar fi un număr prim mare (p) și un rest primitiv modulo (g) (generator). Acești parametri sunt cunoscuți ambelor părți și pot fi folosiți pentru mai multe sesiuni de comunicare.

2. **Generarea Cheilor Private și Publice**: Fiecare parte alege o cheie privată (de exemplu, (a) pentru Alice și (b) pentru Bob) și calculează cheia publică corespunzătoare. De exemplu, Alice calculează $(A = g^a \mod p)$ și Bob calculează $(B = g^b \mod p)$. Cheile private sunt păstrate secrete, în timp ce cheile publice pot fi transmise deschis.

3. **Calculul Cheii Comune**: După schimbul de chei publice, fiecare parte poate calcula cheia comună. De exemplu, Alice poate calcula cheia comună (K) folosind cheia publică a lui Bob: $(K = B^a \mod p)$, iar Bob poate face același lucru folosind cheia publică a lui Alice: $(K = A^b \mod p)$. Ambele părți vor ajunge la aceeași cheie comună, care poate fi utilizată apoi pentru criptarea simetrică.

4. **Exemplu**: Să presupunem că $(p = 11)$ și $(g = 2)$, iar Alice alege (4) și Bob alege (3) . Cheia secretă comună va fi $((2^3)^4 = (2^4)^3 = 2^{12} \mod 11 = 4)$. Un adversar care vede $(2^3 \equiv 8)$ și $(2^4 \equiv 5)$ ar trebui să rezolve una dintre ecuațiile $(2^x \equiv 8)$ și $(2^y \equiv 5)$ pentru a afla cheia secretă partajată, ceea ce este dificil fără cunoașterea cheilor private.

Protocolul Diffie-Hellman este astfel esențial pentru stabilirea unei chei secrete într-un mod sigur, chiar și atunci când comunicația se desfășoară printr-un canal nesigur.